PDPA checklist: {{PROJECT_TITLE}}

Client: {{CLIENT_NAME}} (data user / controller) · **datawazi:** data processor · **Completed:** {{DATE}}

1. What personal data is involved?

Data set / system	Personal data fields	Sensitive? *	Whose data (staff, customers, patients…)	Approx. records
{{}}	{{e.g. name, IC no., phone}}	☐	{{}}	{{}}

*Sensitive personal data under the PDPA includes physical or mental health, political opinions, religious beliefs, and (alleged) offences. The 2024 amendments add biometric data.

☐ **No personal data needed.** We use anonymised or aggregated data only. *(Best option. Prefer it where possible.)*

2. The seven PDPA principles, applied

Principle	Question	Answer / control
General	Is there a lawful purpose and basis (consent or another basis) for this use?	{{}}
Notice & choice	Were data subjects told their data may be used this way?	{{}}
Disclosure	Who will see the data or the outputs? Is any third party involved?	{{}}
Security	Access control, encryption, logging? See section 3	{{}}

Principle	Question	Answer / control
Retention	How long is data kept in the new system? When is it deleted?	{{}}
Data integrity	How do we keep it accurate and up to date?	{{}}
Access	How can a person request or correct their data?	{{}}

3. Controls we will apply

- ☐ Minimum fields only. Drop or mask what isn't needed (e.g. IC numbers)
- ☐ Mask or pseudonymise personal fields in dev/test environments
- ☐ Role-based access; dashboards filtered by role where needed
- ☐ Encryption in transit and at rest
- ☐ Audit log of access to personal data
- ☐ datawazi staff use named accounts; access removed at project end
- ☐ AI features: no personal data sent to external AI services without written approval, and providers' data-use terms checked (no training on client data)

4. Where will data be stored and processed?

- Storage location / region: {{e.g. Azure Southeast Asia (Singapore) / Malaysia West}}
- Any transfer outside Malaysia? ☐ No ☐ Yes → which country and service: {{}}. Basis for the transfer: {{}}
- Client policy requiring data to stay in Malaysia? ☐ Yes ☐ No

5. Breach response

- Client contact for data breaches: {{NAME, PHONE}}
- datawazi notifies the client within **{{24}} hours** of becoming aware of a breach involving client data. Under the 2024 amendments, the client (as data controller) may need to notify the Commissioner and affected people.

6. Agreements in place

- ☐ NDA signed
- ☐ Data Processing Agreement signed (`internal/contracts/dpa-template.md`)

- ☐ Client's DPO consulted (if appointed): {{NAME}}

Client	datawazi
Name / role:	Name / role:
Date:	Date: